

# SITE SECURITY REPORT

Target: https://EXAMPLE.COM

Final URL: https://www.example.com/

Status: 200 IP: 192.0.2.1

Scanned: 2026-09-30T22:27:46.353999+00:00

## 71/100 C Security posture

This report evaluates observable HTTP/TLS/browser security configuration. It is not a penetration test.

6 Passed | 2 Warnings | 2 Failed | 4 Info

## Priority Findings

| Severity | Category               | Finding                                                                                             | Recommendation                                                           |
|----------|------------------------|-----------------------------------------------------------------------------------------------------|--------------------------------------------------------------------------|
| HIGH     | Security Headers       | Content-Security-Policy: No Content-Security-Policy header was observed.                            | Define a restrictive CSP appropriate for the application.                |
| MEDIUM   | Cookies                | Cookie 'bm_sz' lacks Secure. The cookie can potentially be sent over a non-HTTPS connection.        | Add the Secure attribute to cookies that should only travel over HTTPS.  |
| MEDIUM   | Security Headers       | Strict-Transport-Security: HSTS max-age is only 86400 seconds.                                      | Use a sufficiently long max-age after validating your HTTPS deployment.  |
| MEDIUM   | Security Headers       | Referrer-Policy: Referrer-Policy is missing.                                                        | Use a privacy-preserving policy such as strict-origin-when-cross-origin. |
| LOW      | Cookies                | Cookie '_abck' lacks HttpOnly. JavaScript can access this cookie through document.cookie.           | Use HttpOnly for cookies that do not need client-side JavaScript access. |
| LOW      | Cookies                | Cookie '_abck' lacks SameSite. No SameSite policy was declared.                                     | Consider SameSite=Lax or SameSite=Strict where compatible.               |
| LOW      | Cookies                | Cookie 'bm_s' lacks SameSite. No SameSite policy was declared.                                      | Consider SameSite=Lax or SameSite=Strict where compatible.               |
| LOW      | Cookies                | Cookie 'bm_so' lacks HttpOnly. JavaScript can access this cookie through document.cookie.           | Use HttpOnly for cookies that do not need client-side JavaScript access. |
| LOW      | Cookies                | Cookie 'bm_so' lacks SameSite. No SameSite policy was declared.                                     | Consider SameSite=Lax or SameSite=Strict where compatible.               |
| LOW      | Cookies                | Cookie 'bm_sz' lacks HttpOnly. JavaScript can access this cookie through document.cookie.           | Use HttpOnly for cookies that do not need client-side JavaScript access. |
| LOW      | Cookies                | Cookie 'bm_sz' lacks SameSite. No SameSite policy was declared.                                     | Consider SameSite=Lax or SameSite=Strict where compatible.               |
| LOW      | Security Headers       | HSTS does not include subdomains. includeSubDomains was not present.                                | Use includeSubDomains if all relevant subdomains are HTTPS-ready.        |
| LOW      | HTML / JavaScript      | Inline JavaScript detected. 6 inline script block(s) were found.                                    | Prefer nonces/hashes with a strict CSP instead of broad unsafe-inline.   |
| LOW      | Security Headers       | Permissions-Policy: Permissions-Policy is missing.                                                  | Declare browser capabilities that the application does not need.         |
| INFO     | Cross-Origin Isolation | Cross-Origin-Opener-Policy not observed. The site does not opt into a COOP policy on this response. | Consider COOP if your application benefits from cross-origin isolation.  |

## Security Checks

| Category         | Check                     | Status | Observed value / detail                         |
|------------------|---------------------------|--------|-------------------------------------------------|
| Security Headers | Strict-Transport-Security | WARN   | max-age=86400                                   |
| Security Headers | Content-Security-Policy   | FAIL   | No Content-Security-Policy header was observed. |
| Security Headers | X-Content-Type-Options    | PASS   | nosniff                                         |
| Security Headers | X-Frame-Options           | PASS   | sameorigin                                      |
| Security Headers | Referrer-Policy           | FAIL   | Referrer-Policy is missing.                     |

| Category               | Check                        | Status | Observed value / detail                      |
|------------------------|------------------------------|--------|----------------------------------------------|
| Security Headers       | Permissions-Policy           | WARN   | Permissions-Policy is missing.               |
| Cross-Origin Isolation | Cross-Origin-Opener-Policy   | INFO   | cross-origin-opener-policy is not present.   |
| Cross-Origin Isolation | Cross-Origin-Resource-Policy | INFO   | cross-origin-resource-policy is not present. |
| Cross-Origin Isolation | Cross-Origin-Embedder-Policy | INFO   | cross-origin-embedder-policy is not present. |
| Information Disclosure | Server                       | PASS   | No Server header was observed.               |
| CORS                   | Access-Control-Allow-Origin  | INFO   | No CORS allow-origin header was observed.    |
| Caching                | Cache-Control                | PASS   | max-age=0, no-cache, no-store                |
| TLS                    | TLS Protocol                 | PASS   | TLSv1.3                                      |
| TLS                    | Certificate Expiry           | PASS   | Feb 1 23:59:59 2027 GMT                      |

## Cookie Security

| Name  | Secure | HttpOnly | SameSite |
|-------|--------|----------|----------|
| _abck | YES    | NO       | missing  |
| bm_s  | YES    | YES      | missing  |
| bm_so | YES    | NO       | missing  |
| bm_sz | NO     | NO       | missing  |

## TLS / DNS / HTML Observations

### TLS

```
{
  "https": true,
  "version": "TLSv1.3",
  "cipher": "TLS_AES_256_GCM_SHA384",
  "certificate_subject": {
    "countryName": "US",
    "stateOrProvinceName": "Example State",
    "localityName": "Example City",
    "organizationName": "Example Organization, LLC",
    "commonName": "*.example.com"
  },
  "certificate_issuer": {
    "countryName": "US",
    "organizationName": "DigiCert Inc",
    "organizationalUnitName": "www.digicert.com",
    "commonName": "GeoTrust TLS RSA CA G1"
  },
  "not_before": "Jul 18 00:00:00 2026 GMT",
  "not_after": "Feb 1 23:59:59 2027 GMT",
  "days_remaining": 124,
  "san_count": 2
}
```

### DNS

```
{
  "hostname": "www.example.com",
  "a": [
    "192.0.2.1"
  ],
  "aaaa": []
}
```

### HTML

```
{
  "is_html": true,
  "title": "Example Domain",
  "scripts": 45,
  "inline_scripts": 6,
  "external_scripts": 39,
  "external_script_urls": [
    "https://cdn.example.com/user-consent/index-gam.min.js",
    "/theme-loader.js",
  ]
}
```

```
"/_next/static/chunks/polyfills-REDACTED.js",
"/_next/static/chunks/webpack-REDACTED.js",
"/_next/static/chunks/framework-REDACTED.js",
"/_next/static/chunks/main-REDACTED.js",
"/_next/static/chunks/pages/_app-REDACTED.js",
"... (28 more /_next/static/chunks/*-REDACTED.js files)",
"/_next/static/BUILD_ID_REDACTED/_buildManifest.js",
"/_next/static/BUILD_ID_REDACTED/_ssgManifest.js",
"https://securepubads.g.doubleclick.net/tag/js/gpt.js",
"https://tags.example.com/web/prod/utag.js",
"/REDACTED_BOT_MANAGER_PATH_1",
"/REDACTED_BOT_MANAGER_PATH_2?v=REDACTED"
],
"forms": 1,
"password_forms": 0,
"insecure_password_forms": [],
"mixed_content": [],
"iframes": 0,
"images": 103,
"links": 302
}
```

## Redirect Chain

| Status | From                     | To                       |
|--------|--------------------------|--------------------------|
| 301    | https://example.com/     | https://www.example.com/ |
| 200    | https://www.example.com/ | https://www.example.com/ |

*Methodology note: This report is an independent passive configuration assessment. A PASS does not prove that an application is free of vulnerabilities, and a missing header does not necessarily mean the application is exploitable. Header recommendations should be reviewed against the application's functionality and threat model.*